

PatchIQ-iA Security Analysis

Sample 01 — Multiple Vulnerability Detection

1. Objective

The objective of this test is to evaluate whether PatchIQ-iA can identify multiple security vulnerabilities within a single Pull Request. The submitted code intentionally contains a hardcoded secret, command injection vulnerabilities, and insecure deserialization. This test evaluates PatchIQ-iA's ability to detect and report these issues through its security analysis pipeline.

2. Input Code

The following vulnerable Python code was submitted as part of the Pull Request:

```
import os
import pickle
import subprocess

API_KEY = "sk_test_123456789abcdef"

user_input = input("Enter command: ")
os.system(user_input)

data = input("Enter serialized data: ")
obj = pickle.loads(data)

filename = input("Enter filename: ")
subprocess.run(f"cat {filename}", shell=True)
```

3. PatchIQ-iA Output

The following screenshot shows the actual security review generated by PatchIQ-iA for this Pull Request.

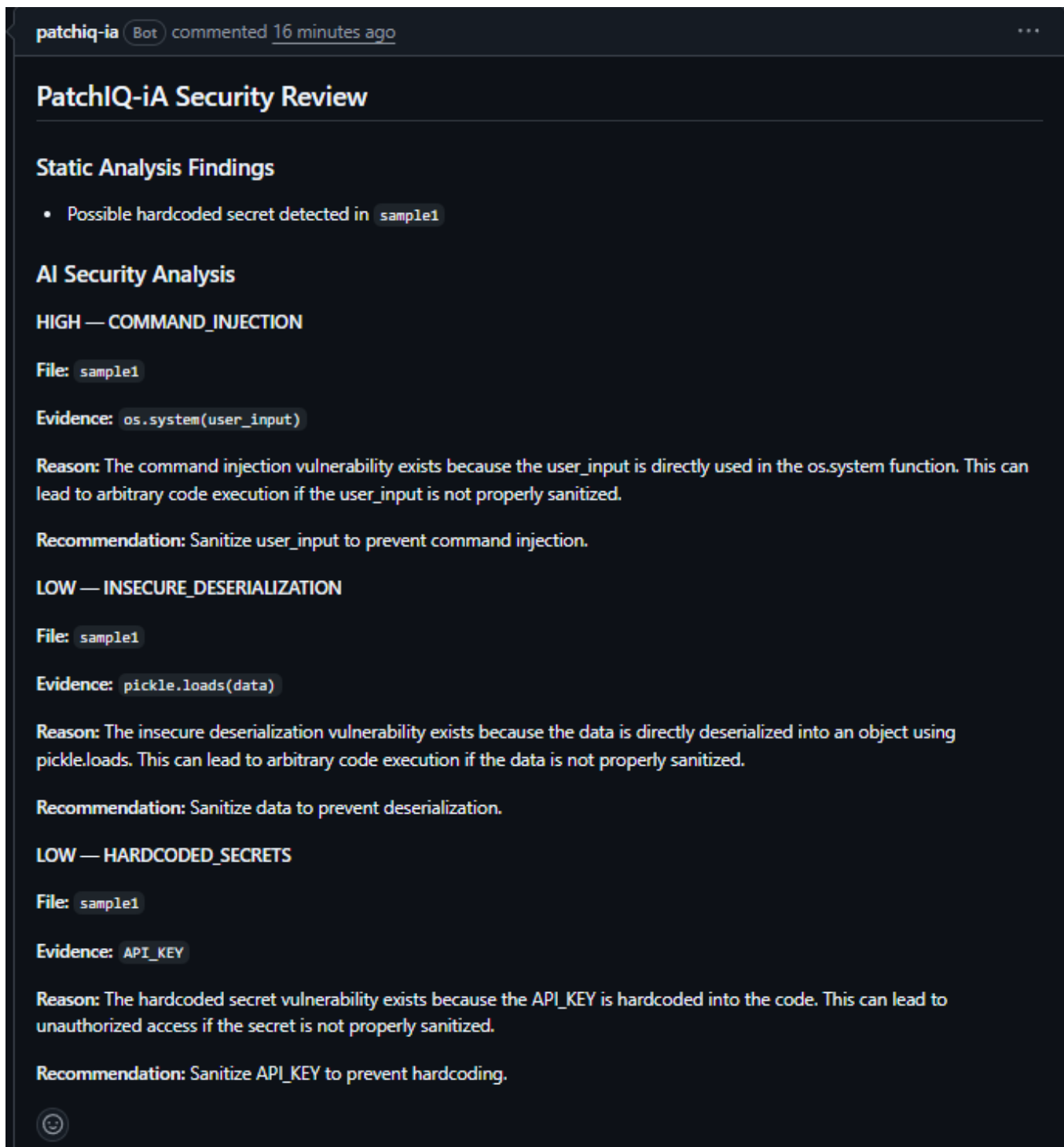


Figure 1. Actual PatchIQ-iA Security Review generated during the test.

4. Conclusion

PatchIQ-iA successfully analyzed the Pull Request and identified multiple security-sensitive patterns within the submitted code. The static analysis detected a possible hardcoded secret, while the AI security analysis identified command injection, insecure deserialization, and a hardcoded-secret finding. The generated findings included severity, evidence, reasoning, and recommendations, demonstrating the system's ability to produce a structured security review from a vulnerable Pull Request.